



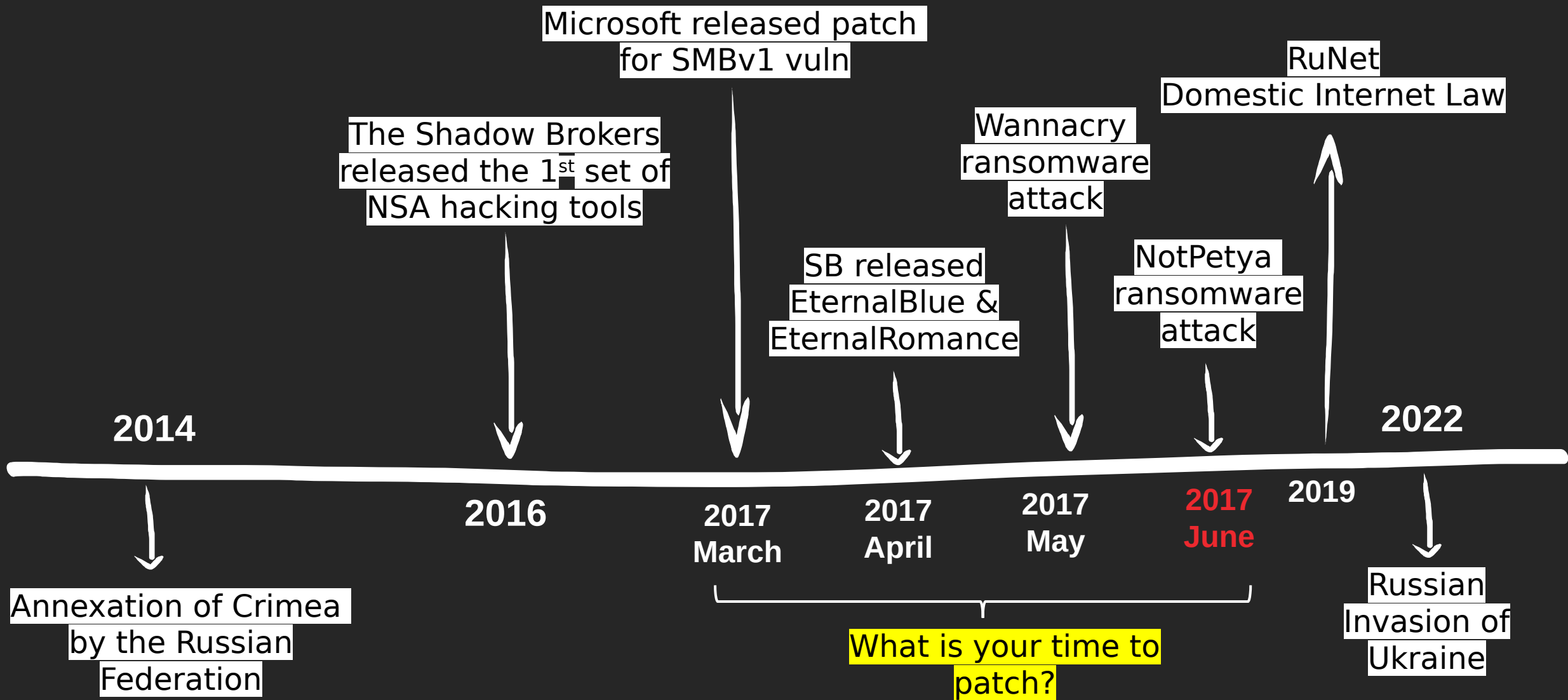
UKRAINE TESTBED

COLLATERAL DAMAGE &
LESSONS LEARNED
FROM CYBERWARFARE

NotPetya 2017



Introduction





*“ATTACKS WERE OFTEN TRIED OUT
IN UKRAINE BEFORE BEING EXPANDED TO
EU COUNTRIES”*

JUHAN LEPASSAAR
Executive Director of ENISA

*“THEY FIGHT PHYSICIALLY IN UKRAINE,
BUT DIGITALLY ALSO ACROSS EUROPE”*

.Not Petya





NotPetya / Nyetya / GoldenEye / DiskCoder.C / ExPetr / ...

A politically-motivated attack against Ukraine

Did you have business in Ukraine? So, you were a potential victim

Fortune 500 affected companies: Maersk, FedEx, Merck, Saint-Gobain, ...

Billions of Dollars in Losses (Direct & Indirect). Still counting...



A **Wiper** and not a Ransomware

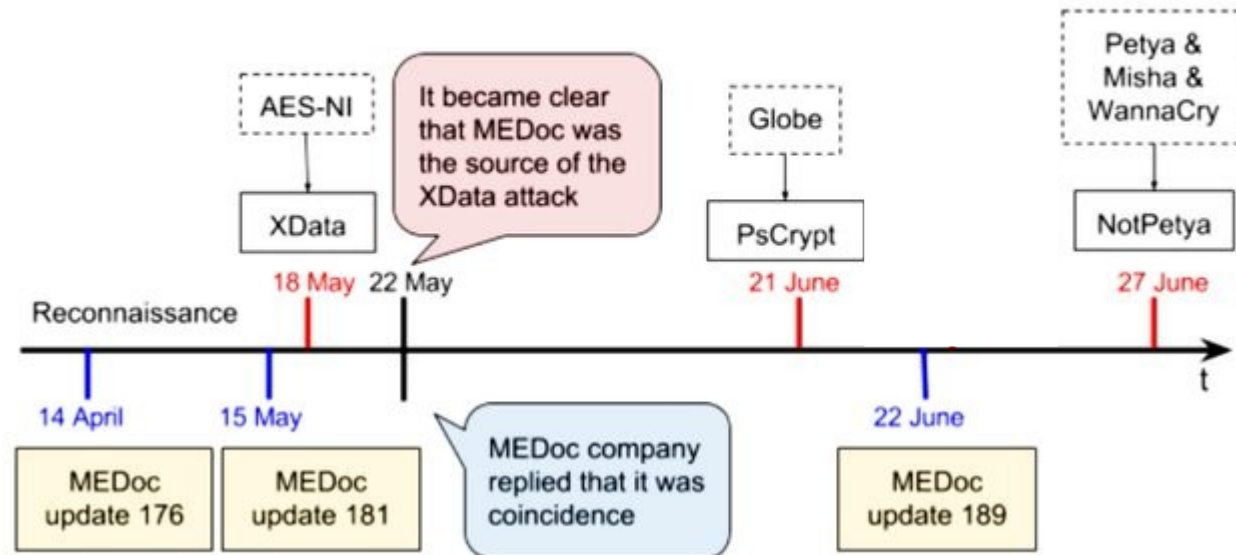
Only **one** vulnerable device to allow lateral movement

Propagation at the “speed of light”

Exploits developed by NSA, stolen by SB Group to attack US allies

Initial Attack Vector

NotPetya attack through M.E.Doc

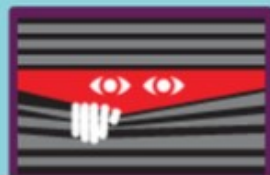


Source: Virus Bulletin 2017 Madrid Conference



Оновлено: Будьте пильні: вірусна атака на корпоративний сектор!

22.05.2017



У мережі з'явився вірус XData Ransomware. Вірус спрямований на корпоративний сектор і діє за схемою WannaCry - шифрує файли на

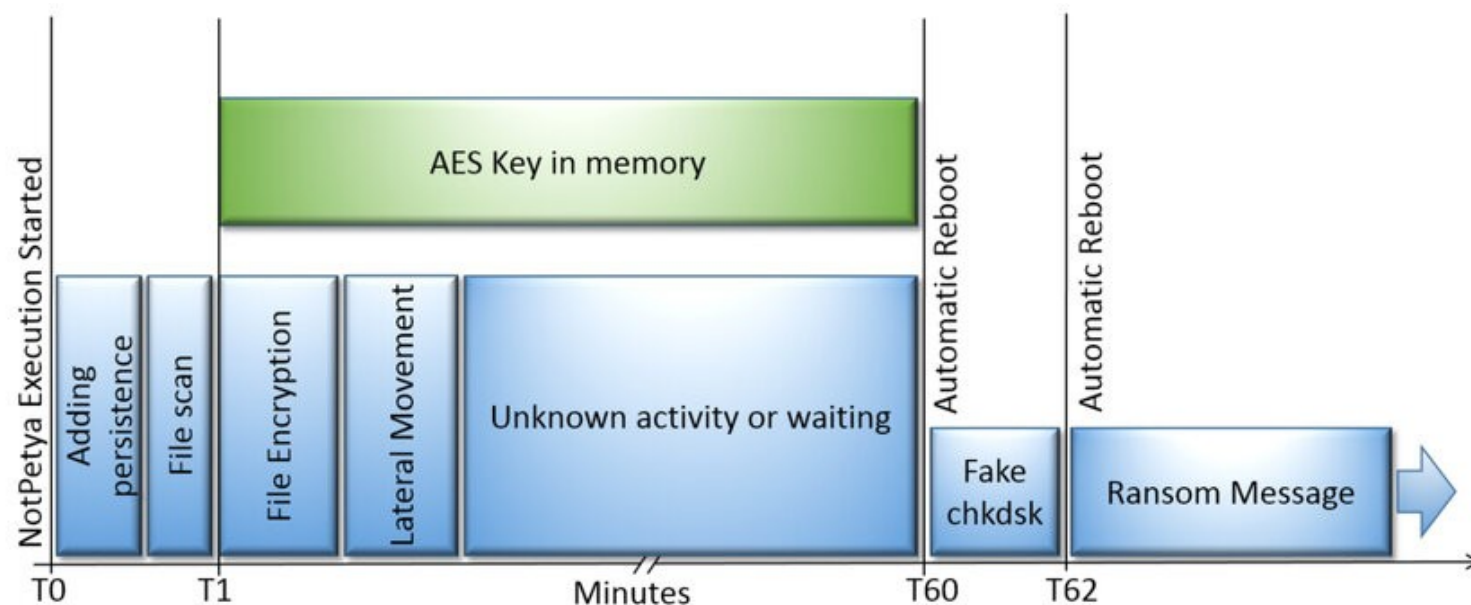
в мере
- саме
результ
програ
вірус
«M.E.D
безпе
велик
аналіз
оновл

Users who became infected with the XData also have the M.E.Doc program damaged. This coincidence could serve as a precondition for the association between the virus and the program. Similar conclusions are clearly false, because the "M.E.Doc" developer, as a responsible software supplier, monitors the security and purity of its own code.

To do this, we have entered into agreements with large antivirus companies to provide executable binary files for analysis and confirmation of their security. This means that before the release of each update, "M.E.Doc" sends its files to the antivirus companies for analysis.

Переконатися в цьому може кожен користувач. За допомогою www.virustotal.com можна перевірити, як ті чи інші антивірусні програми реагують на оновлення. Хеш-коди всіх оновлень знаходяться в прямому доступі на сайті програми.

NotPetya, a Swiss Army Knife



- **EternalBlue**: Critical vulnerability in SMBv1 protocol. RCE
- **EternalRomance**: maximize the spread of the malware
- **PsExec**: Light-weight legitimate tool to execute commands remotely
- **WMIC**: Exec Administrative tasks on local and remote Windows Systems
- **Mimikatz**: Tool to extract credentials from the memory



Maersk DC recovery

Maersk's 150 or so domain controllers were programmed to sync their data with one another, so that, in theory, any of them could function as a backup for all the others. But that decentralized backup strategy hadn't accounted for one scenario: where every domain controller is wiped simultaneously. "If we can't recover our domain controllers," a Maersk IT staffer remembers thinking, "we can't recover anything."

After a frantic global search, the admins finally found one lone surviving domain controller in a remote office—in Ghana.

After a frantic search that entailed calling hundreds of IT admins in data centers around the world, Maersk's desperate administrators finally found one lone surviving domain controller in a remote office—in Ghana. At some point before NotPetya struck, a blackout had knocked the Ghanaian machine offline, and the computer remained disconnected from the network. It thus contained the singular known copy of the company's domain controller data left untouched

by the malware—all thanks to a power outage. "There were a lot of joyous whoops in the office when we found it," a Maersk administrator says.

The Untold Story of NotPetya, the Most Devastating Cyberattack in History

Source: Wired.com



Maersk DC recovery

About **two weeks after** the attack, Maersk's **network had finally reached a point** where the company could **begin** reissuing personal computers to the majority of staff. Back at the Copenhagen headquarters, a cafeteria in the basement of the building was turned into a reinstallation assembly line. Computers were lined up 20 at a time on dining tables as help desk staff walked down the rows, inserting USB drives they'd copied by the dozens, clicking through prompts for hours.

A few days after his return from Maidenhead, Henrik Jensen found his laptop in an alphabetized pile of hundreds, its hard drive wiped, a clean image of Windows installed. Everything that he and every other Maersk employee had stored locally on their machines, from notes to contacts to family photos, was gone.

FIVE MONTHS AFTER Maersk **had recovered from its NotPetya attack**, Maersk chair Jim Hagemann Snabe sat onstage at the World Economic Forum meeting in Davos, Switzerland, and lauded the "heroic effort" that went into the company's IT rescue

operation. From June 2017, when the tense engineers in Maidenhead set up a connection to the Ghana office, California, ahead of a 10-day deadline, however, **they found its bandwidth was so thin that it would take days** to transmit the several-hundred-gigabyte domain controller backup to the UK. Their next idea: put a Ghanaian staffer on the next plane to London. But none of the West African office's employees had a British visa.

So the Maidenhead operation arranged for a kind of relay race: One staffer from the Ghana office flew to Nigeria to meet another Maersk employee in the airport to hand off the very precious hard drive. That staffer then boarded the **six-and-a-half-hour flight** to Heathrow, carrying the keystone of Maersk's entire recovery process.

The Untold Story of NotPetya, the Most Devastating Cyberattack in History

Source: Wired.com

Lessons Learned





- Facing an attack is inevitable
- Develop and exercise your Disaster Recovery Plan / BCP
- Tabletop Exercises. Everyone must be involved

There's no harm in hoping for the best as long as you're prepared for the worst.

Stephen King



- Backup and regularly test them (Encrypted, Offline, ...)
- Network segmentation (WAN and LAN)
- Unique and Complex passwords. Least Privilege principle
- Keep your systems patched
- Do not relax, protect your critical systems
- User Security Awareness Training



Are you prepared for the next
Big Cyber Attack?

"The time to repair the roof is when the sun is shining"
- John F. Kennedy

OBRIGADO